

Rapport n°3

Audit selon la méthode unifiée MUSA

Application auditée : GIDOCEP

Développeur : SOLTEC (Solutions Techniques)

Référence : MUSA-AUDIT-2026-01

Document rédigé selon le modèle de rapport d'audit MUSA (Annexe I du mémoire)

En-tête du rapport

Titre	Audit de sécurité applicative de GIDOCEP : Méthode MUSA		
Référence	MUSA-AUDIT-2026-01	Version	1.0
Application auditée	GIDOCEP	Niveau d'audit	☒ 2 ☐ 1 ☐ 3
Période d'audit	Mars - Avril 2026	Structure auditée	SOLTEC (Solutions Techniques)
Lead auditor	TOMI OLAMA Gabrielle Solange	Visa	
Date de transmission		Statut	☒ Provisoire ☐ Définitif
Classification	Confidentiel		

SECTION 1 : Résumé exécutif

Métriques principales

Métrique	Valeur
Taux de conformité global (TC)	34 %
Taux de conformité OWASP N2 (TCN2)	36,2 %
Score de risque moyen (R)	8,17 / 16
Entropie globale (Hglobal)	0,317 (accord fort : audit fiable)
Score de maturité global	29,2 % (Niveau 1 : Initial)

Forces identifiées

- ✦ 1. Séparation stricte des tâches entre Ordonnateur, Contrôleur Financier et Agent Comptable
- ✦ 2. Traçabilité des opérations comptables (journalisation des actions)
- ✦ 3. Séparation des environnements (développement / test / production)
- ✦ 4. Expiration de session après inactivité (10 minutes)

Vulnérabilités critiques et élevées

- ✦ 1. Injection SQL sur l'endpoint de recherche (R = 16), impact métier : permet à un Agent Comptable de contourner la séparation des tâches et d'accéder aux engagements de l'Ordonnateur
- ✦ 2. XSS stockée via le champ libellé (R = 9)
- ✦ 3. IDOR sur l'identifiant d'établissement (R = 9)
- ✦ 4. Mots de passe sur post-it / postes non verrouillés (R = 9)

Recommandation principale

Mettre en place une gouvernance de la sécurité (politique, PRA, sensibilisation) ET corriger les vulnérabilités techniques critiques (injection SQL, XSS, IDOR) qui fragilisent la logique métier.

SECTION 2 : Contexte et périmètre

2.1 Organisation auditée

SOLTEC est une PME camerounaise de moins de 20 employés, spécialisée dans le développement de solutions informatiques pour les administrations publiques.

2.2 Application auditée

GIDOCEP est l'application de gestion comptable des établissements publics camerounais. Elle gère les opérations de dépenses et de recettes selon le circuit à trois acteurs (Ordonnateur → Contrôleur Financier → Agent Comptable) défini par la circulaire N° 13/001/C/MINFI du 08 janvier 2013.

2.3 Périmètre inclus

- ✦ Application GIDOCEP (production)
- ✦ Base de données HFSQL Classic
- ✦ Serveur IIS hébergeant l'application
- ✦ Interfaces utilisateur

2.4 Périmètre exclu

- ✦ Postes clients des utilisateurs
- ✦ Infrastructure réseau des établissements
- ✦ Applications tierces non développées par SOLTEC

2.5 Niveau d'audit

Niveau 2 (Standard) : 100 contrôles OWASP ASVS.

2.6 Contraintes et limitations

- ✦ Accès partiel au code source
- ✦ Entropie calculée à partir de données d'entraînement pour valider le fonctionnement de l'outil
- ✦ Audit réalisé dans le cadre d'un mémoire de fin d'études

SECTION 3 : Méthodologie

3.1 Référentiels utilisés

- ✦ ISO 19011:2018 : Procédure (5 phases d'une mission d'audit)
- ✦ OWASP ASVS v4.0.3 : Contenu technique (100 contrôles sécurité applicative, niveau 2)
- ✦ ISO 27001:2022 : Contenu organisationnel (93 contrôles, domaines 5, 6, 7, 8)
- ✦ NIST SP 800-115 : Méthodologie de test (planification, exécution, post-exploitation)

- ✦ Normes IIA : Gouvernance (indépendance, documentation, suivi, escalade)
- ✦ Entropie de Shannon : Mesure de fiabilité (accord inter-auditeurs, $H < 0,5$ = fiable)

3.2 Outils utilisés

Type de test	Outil
Scan réseau	Nmap (secondaire recommandé : Masscan)
Scan vulnérabilités	Nuclei (secondaire recommandé : OpenVAS)
Test dynamique (DAST)	OWASP ZAP (secondaire recommandé : Burp Suite)
Tests d'authentification	Hydra / Manuel
Contrôle d'accès	Burp Repeater / Manuel
Logique métier	Manuel / Burp Repeater

3.3 Équipe d'audit

- ✦ TOMI OLAMA Gabrielle Solange, Lead auditor : sécurité applicative, audit SI, pilotage, collecte des preuves, rédaction
- ✦ M. MBOUL Patrick, Expert métier : comptabilité publique, validation fonctionnelle
- ✦ M. NJEI CHECK, Référent institutionnel : réglementation ANTIC, alignement réglementaire

3.4 Calcul de l'entropie (mesure de fiabilité)

L'entropie de Shannon permet de mesurer l'accord entre les auditeurs :

Source	Nb assertions	H moyen	Interprétation
Audit organisationnel (PT02)	69	0,289	Accord fort
OWASP ASVS N2 (PT03)	47	0,300	Accord fort
Logique métier (PT03)	10	0,400	Accord fort

Entropie globale : $H_{global} = 0,317 (< 0,5)$ → audit fiable, bonne reproductibilité

SECTION 4 Synthèse des résultats

4.1 Distribution des constats

Catégorie	Nombre
Conformes	11
Non conformes	10
Zones grises	3

4.2 Distribution des vulnérabilités par niveau de risque

Niveau	Nombre	Pourcentage
Critique (R = 16)	1	17 %
Élevé (R = 9-15)	3	50 %
Modéré (R = 4-8)	1	17 %
Faible (R = 1-3)	1	16 %

4.3 Répartition par catégorie OWASP

Catégorie	Nb vulnérabilités
V2 - Authentification	3
V3 - Gestion de session	1
V4 - Contrôle d'accès	1
V5 - Validation des entrées	2
V6 - Cryptographie	1
V14 - Configuration	1

4.4 Score de maturité par domaine

Domaine	Score	Niveau
Politique de sécurité	25 %	Niveau 1 (Initial)
Gestion des accès	50 %	Niveau 2 (Défini)
Développement sécurisé	25 %	Niveau 1 (Initial)
Gestion des incidents	25 %	Niveau 1 (Initial)
Continuité d'activité	25 %	Niveau 1 (Initial)
Sensibilisation	25 %	Niveau 1 (Initial)
Moyenne	29,2 %	Niveau 1 (Initial)

SECTION 5 Détail des vulnérabilités

Fiche n°1 (Critique)

Identifiant	DAST-001 / CONSTAT-001
Titre	Injection SQL sur l'endpoint de recherche
Catégorie OWASP	V5.3.1
Contrôle ISO 27001	8.8 (Gestion des vulnérabilités techniques)
Description technique	L'endpoint /recherche?q= est vulnérable à une injection SQL. L'application construit des requêtes SQL par concaténation de chaînes, permettant à un attaquant de modifier la requête et d'extraire des données.
Description métier	L'endpoint de recherche est accessible aux 3 profils (Ordonnateur, Contrôleur Financier, Agent Comptable). Un Agent Comptable pourrait exploiter cette faille pour

	accéder aux engagements de l'Ordonnateur, contournant ainsi la séparation des tâches.
Preuve	Capture ZAP-03 / Rapport SQLMap
Impact technique	Extraction de données de la base de données
Impact métier	Confidentialité violée : un Agent Comptable voit les engagements avant leur validation Séparation des tâches contournée : la règle d'or de la gestion publique est fragilisée Risque de fraude : accès à des informations normalement réservées
Probabilité (P)	4 (Élevée) : exploitation triviale, outil public disponible (SQLMap)
Impact (I)	4 (Critique) : finances publiques, séparation des tâches
Score de risque	[object Object]
Entropie (Hi)	0,00 (accord fort)
Recommandation	Remplacer les requêtes SQL par des requêtes paramétrées ou utiliser un ORM ET renforcer les contrôles d'accès par profil
Priorité	[object Object]
Échéance	J+2 (48 heures)
Responsable	Lead développeur SOLTEC

Fiche n°2 (Élevé)

Identifiant	DAST-002 / CONSTAT-002
Titre	XSS stockée via le champ libellé des écritures comptables
Catégorie OWASP	V5.2.1
Description technique	Le champ libellé des écritures comptables n'est pas correctement encodé avant affichage, permettant l'injection de scripts JavaScript persistants.
Description métier	Un attaquant pourrait injecter un script qui s'exécute lorsqu'un Contrôleur Financier consulte l'écriture, permettant de voler sa session ou de modifier des données à son insu.
Preuve	Capture ZAP-02
Impact technique	Exécution de code JavaScript dans le navigateur des utilisateurs
Impact métier	Vol de session d'acteurs clés (Ordonnateur, Contrôleur Financier) Falsification potentielle d'écritures comptables Atteinte à l'intégrité des données
Probabilité (P)	3 (Modérée)
Impact (I)	3 (Significatif)
Score de risque	[object Object]
Entropie (Hi)	0,00 (accord fort)
Recommandation	Encoder systématiquement les sorties HTML côté serveur

Priorité	[object Object]
Échéance	2 semaines
Responsable	Lead développeur SOLTEC

Fiche n°3 (Élevé)

Identifiant	DAST-004 / CONSTAT-003
Titre	IDOR sur l'identifiant d'établissement
Catégorie OWASP	V4.2.2
Description technique	Le paramètre id_etablissement dans l'URL n'est pas correctement protégé. Sa modification permet d'accéder aux données d'un autre établissement.
Description métier	GIDOCEP est décentralisé : chaque établissement gère ses propres données. Un Agent Comptable de l'établissement A pourrait modifier l'URL pour accéder aux données de l'établissement B, violant la séparation des données entre établissements.
Preuve	Capture ZAP-04
Impact technique	Accès non autorisé aux données
Impact métier	Violation de la confidentialité des données Risque de fuite d'informations financières entre établissements Non-respect du principe de séparation des données
Probabilité (P)	3 (Modérée)
Impact (I)	3 (Significatif)
Score de risque	[object Object]
Entropie (Hi)	0,92 (discussion requise)
Recommandation	Appliquer un contrôle d'accès au niveau de chaque objet (établissement) côté serveur
Priorité	[object Object]
Échéance	2 semaines
Responsable	Lead développeur SOLTEC

Fiche n°4 (Élevé)

Identifiant	PHY-001 / CONSTAT-004
Titre	Mots de passe sur post-it / postes non verrouillés
Contrôle ISO 27001	7.7 (Bureau propre, écran propre)
Description	L'inspection physique a révélé des mots de passe affichés sur des post-it et des écrans non verrouillés en cas d'absence.
Preuve	Photo des post-it (floutée) / observation directe
Impact métier	Compromission directe des comptes utilisateurs Accès non autorisé aux données financières

	Risque de fraude
Probabilité (P)	3 (Modérée)
Impact (I)	3 (Significatif)
Score de risque	[object Object]
Entropie (Hi)	0,92 (discussion requise)
Recommandation	Mettre en place une politique de bureau propre Activer le verrouillage automatique des écrans Former les utilisateurs
Priorité	[object Object]
Échéance	2 semaines
Responsable	RSSI SOLTEC

Fiche n°5 (Modéré)

Identifiant	DAST-005 / CONSTAT-005
Titre	En-têtes HTTP de sécurité absents (CSP, HSTS)
Catégorie OWASP	V14.3.2
Description technique	Les en-têtes de sécurité HTTP (Content Security Policy, HSTS) ne sont pas configurés.
Description métier	L'absence de ces en-têtes rend l'application plus vulnérable aux attaques XSS et clickjacking, utilisables pour compromettre les comptes des acteurs du circuit budgétaire.
Preuve	DAST-005
Impact technique	Vulnérabilités XSS et clickjacking facilitées
Impact métier	Risque de vol de session Risque de manipulation d'écritures comptables
Probabilité (P)	2 (Faible)
Impact (I)	2 (Limité)
Score de risque	[object Object]
Entropie (Hi)	0,92 (discussion requise)
Recommandation	Configurer les en-têtes CSP, HSTS et X-Frame-Options
Priorité	[object Object]
Échéance	1 mois
Responsable	Administrateur système

Fiche n°6 (Faible)

Identifiant	DAST-006 / CONSTAT-006
--------------------	------------------------

Titre	Divulgateion de la bannière serveur
Catégorie OWASP	V14
Description	La version du serveur IIS est exposée dans les en-têtes HTTP.
Preuve	DAST-008 / Lynis
Impact métier	Facilitation des attaques ciblées
Probabilité (P)	2 (Faible)
Impact (I)	1 (Négligeable)
Score de risque	[object Object]
Entropie (Hi)	0,00 (accord fort)
Recommandation	Masquer la version du serveur dans les en-têtes HTTP
Priorité	[object Object]
Échéance	Planifié
Responsable	Administrateur système

Non-conformités organisationnelles complémentaires (CONSTAT-007 à CONSTAT-010)

ID	Titre	Contrôle ISO	P	I	R	Priorité
ORG-001	Absence de politique de sécurité formelle	5.1	3	3	9	Élevé
ORG-002	Absence de procédure de gestion des incidents	5.24	3	3	9	Élevé
ORG-003	Absence de PRA / sauvegardes non testées	5.29	2	4	8	Modéré
ORG-004	Aucune formation/sensibilisation sécurité (12 mois)	6.3	3	2	6	Modéré

SECTION 6 Plan d'action

ID	Recommandation	Priorité	Responsable	Échéance	Indicateur
REC-001	Corriger l'injection SQL (requêtes paramétrées)	Critique	Lead dev	J+2	Rejet SQLMap sur l'endpoint
REC-002	Migrer le hachage MD5 vers bcrypt/Argon2	Critique	Lead dev	J+2	Revue de code : aucun MD5 résiduel
REC-003	Corriger l'IDOR / cloisonner les établissements	Élevé	Lead dev	M+1	Test d'accès croisé en échec
REC-004	Corriger la faille XSS (encodage des sorties)	Élevé	Lead dev	M+1	Test XSS en échec
REC-005	Mettre en place un blocage après 5 échecs	Élevé	Lead dev	M+1	Blocage confirmé après 5 échecs

ID	Recommandation	Priorité	Responsable	Échéance	Indicateur
REC-006	Mettre en place une politique de bureau propre	Élevé	RSSI	M+1	Aucun post-it visible, verrouillage auto
REC-007	Rédiger et faire signer une politique de sécurité	Élevé	Direction	M+1	Politique signée et diffusée
REC-008	Élaborer un Plan de Reprise d'Activité (PRA)	Modéré	RSSI	M+2	PRA testé et daté
REC-009	Mettre en place une procédure de gestion des incidents	Modéré	RSSI	M+2	Procédure écrite et testée
REC-010	Mettre en place un programme de sensibilisation	Modéré	RSSI	M+2	Attestations de formation
REC-011	Configurer les en-têtes HTTP de sécurité	Modéré	Admin sys	M+2	En-têtes présents (scan)
REC-012	Masquer la bannière serveur et les stack traces	Faible	Admin sys	M+3	Bannière non divulguée

SECTION 7 Annexes

- ✦ Papiers de travail MUSA : PT01 (Initiation), PT02 (Audit organisationnel), PT03 (Audit technique), PT04 (Matrice des risques), PT05 (Rapport), PT06 (Suivi post-audit)
- ✦ Captures d'écran : OWASP ZAP (tableau de bord des alertes), Nmap (scan réseau), Nuclei (scan de vulnérabilités)
- ✦ Exports d'outils : rapport OWASP ZAP (HTML), rapport SQLMap (injection SQL), rapport SAST (SonarQube)
- ✦ Documents administratifs : charte d'audit signée, déclarations d'indépendance des auditeurs, procès-verbaux des réunions

SECTION 8 Synthèse de la valeur ajoutée de MUSA

Vulnérabilité	Audit sécurité seul (ANTIC)	Audit applicatif seul (CONSUPE)	MUSA (fusion)
Injection SQL	Détectée	Non détectée	Détectée + impact métier évalué (séparation des tâches)
XSS stockée	Détectée	Non détectée	Détectée + contexte métier (ciblage des acteurs)
IDOR	Détectée	Non détectée	Détectée + impact métier (séparation des données entre établissements)
Absence de séparation des tâches	Non détectée	Détectée	Détectée + recommandation de sécurité associée
Absence de politique de sécurité	Non détectée	Détectée	Détectée
Absence de PRA	Non détectée	Détectée	Détectée
Absence de formation utilisateurs	Non détectée	Détectée	Détectée

« Une injection SQL dans un module de recherche n'a pas le même impact qu'une injection SQL dans un module de validation des ordres de paiement. MUSA, en fusionnant sécurité et logique métier, évalue l'impact réel de chaque vulnérabilité sur le fonctionnement de l'application. C'est la vision complète que seule une méthode unifiée peut offrir. »

Document préparé dans le cadre du mémoire MUSA : Comparaison des approches ANTIC, CONSUPE et MUSA